Trusted Production Environment

Prof Konstantinos Markantonakis

K.Markantonakis@rhul.ac.uk
http://www.isg.rhul.ac.uk/~kostasm
http://www.markantonakis.com

Smart Card and IoT Security Centre (SCC)
Information Security Group
Royal Holloway, University of London
http://www.scc.rhul.ac.uk

Original material from Giesecke & Devrient

Learning Objectives

- Appreciate the smart card production process and understand finalisation/completion, initialisation and personalisation
- Compare the various methods of card construction and be aware of printed components and their importance
- Consider information security measures for customer orders, data storage and response data handling
- Contrast methods for security key generation/storage
- Recognise the high levels of physical and process security to maintain customer confidence

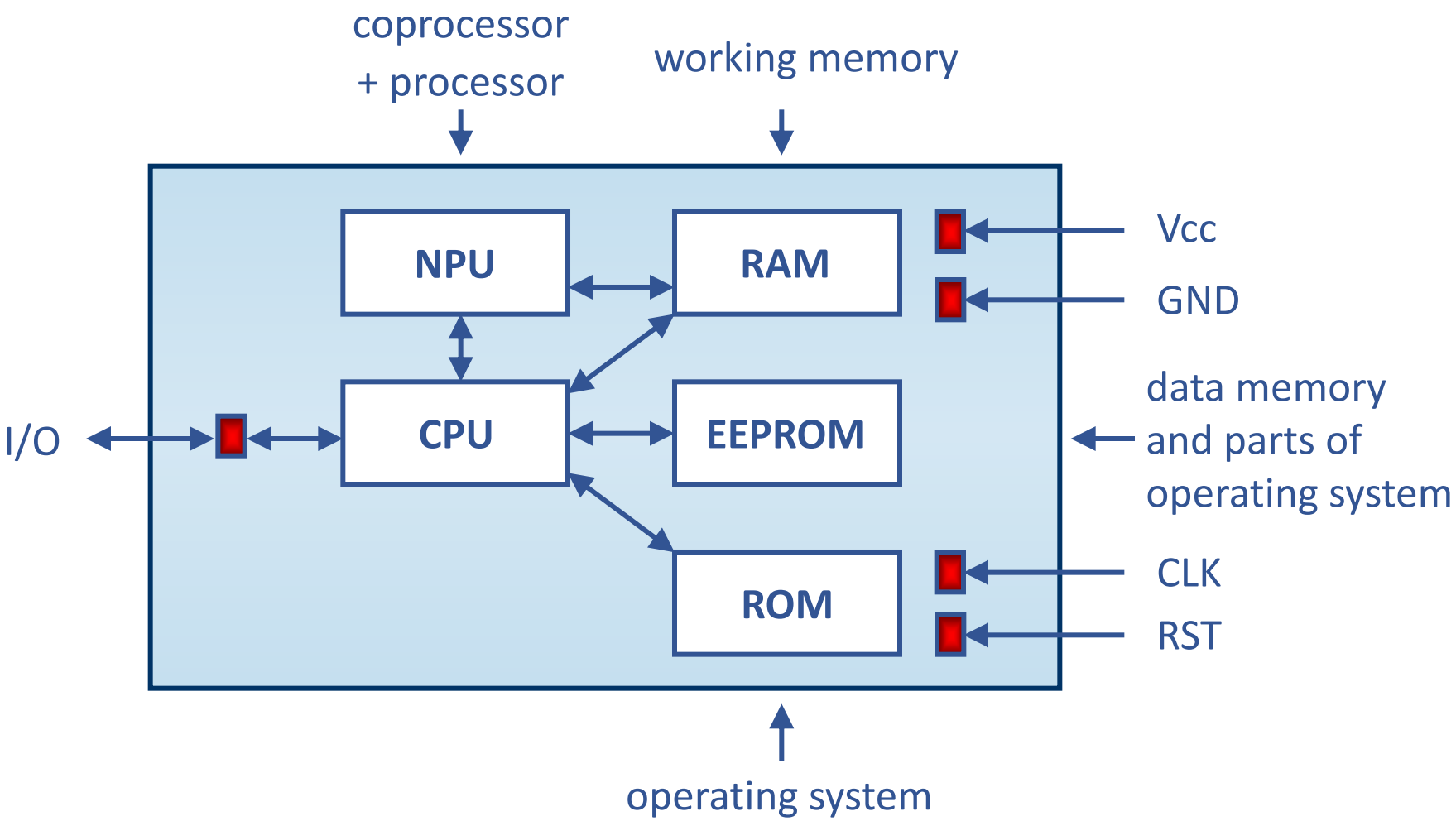
Production security objectives

- prevent key disclosure
- ensure integrity of OS/apps
- enforce separation of roles
- maintain auditability and non-repudiation of processes
- protect response data end-to-end

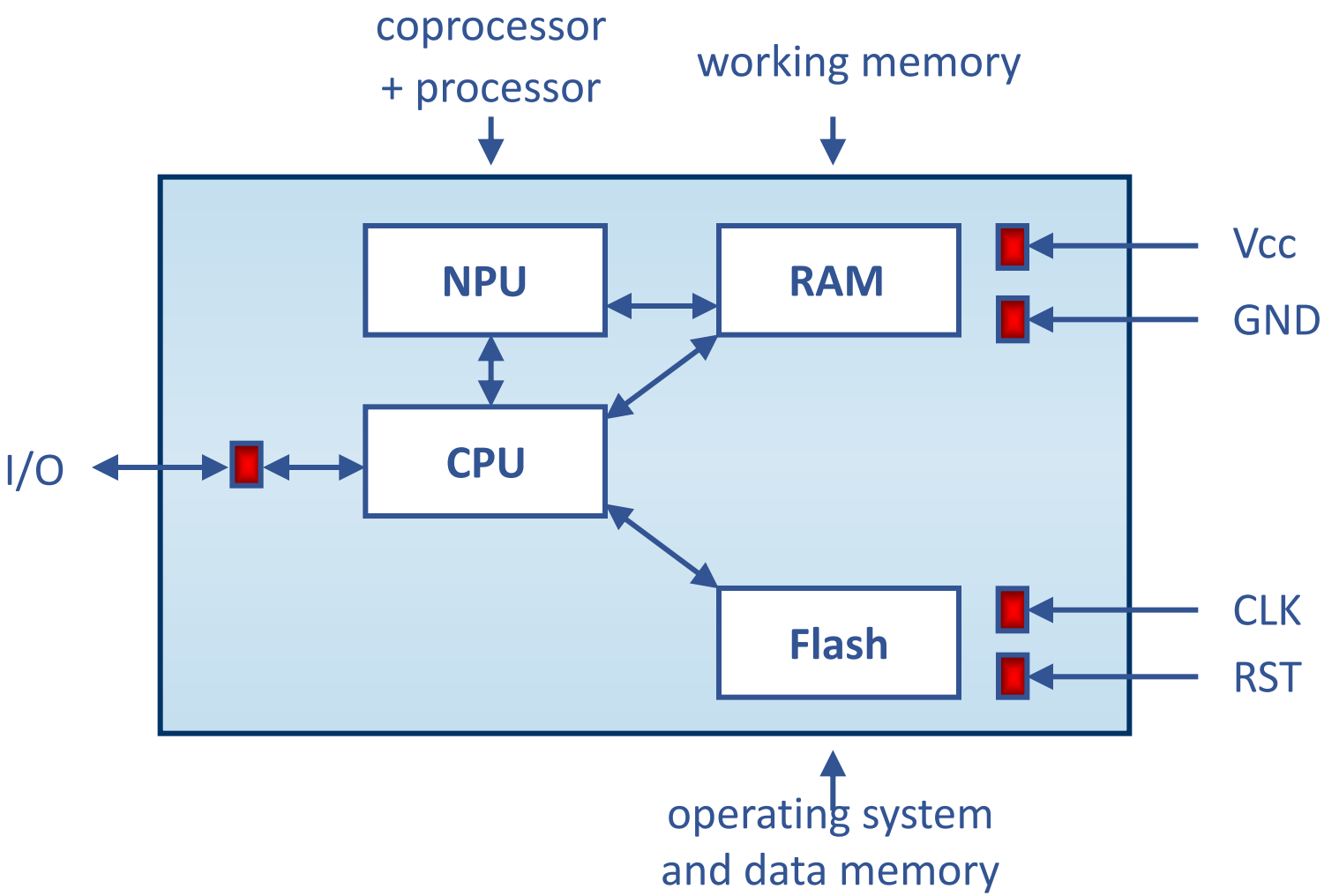
Agenda

- Some Basics
- Card Manufacturing
- Key and Data Management
- Smart Card Lifecycle – IT Perspective
- Typical Example

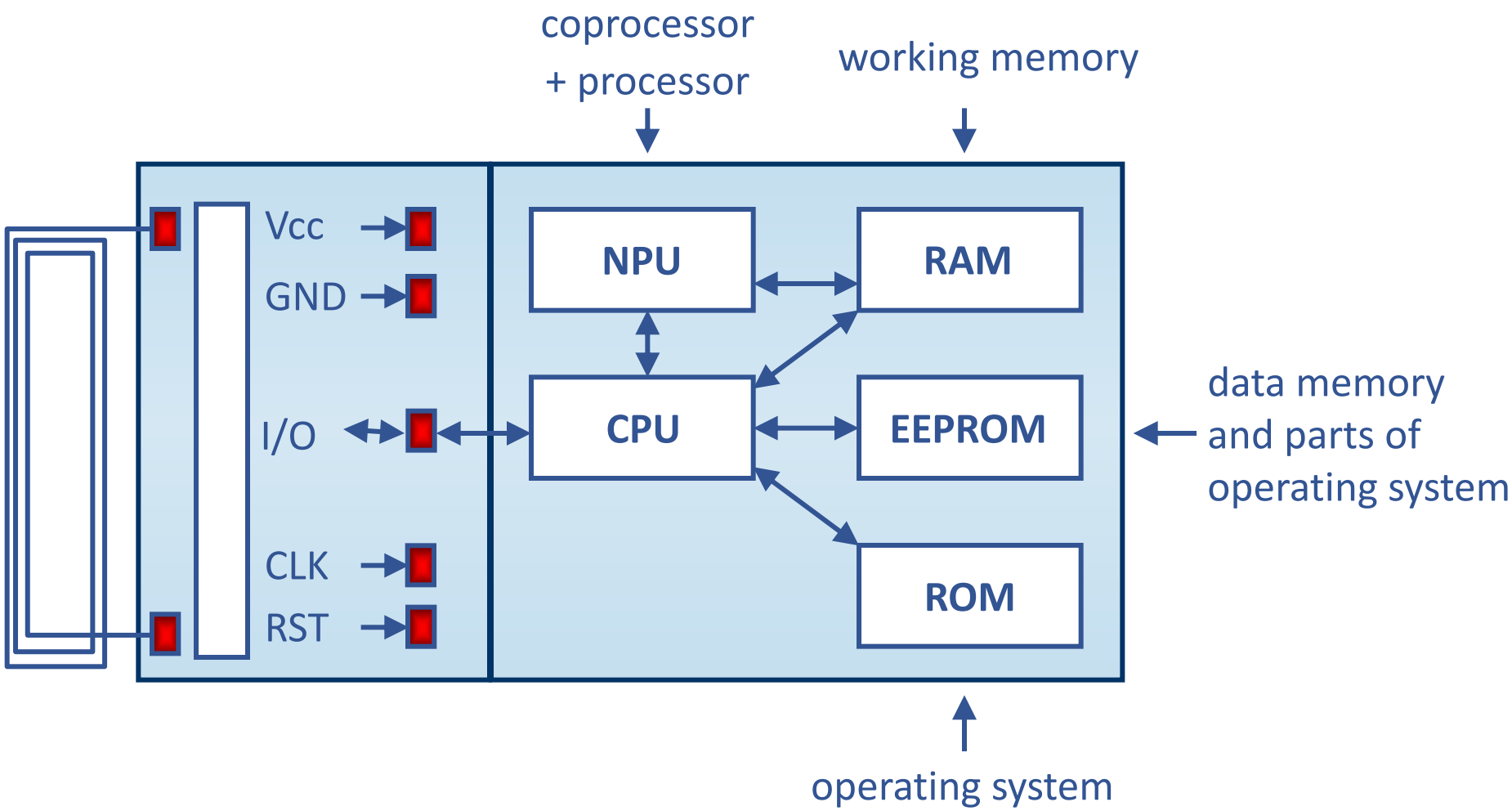
Contact Microcontroller with ROM



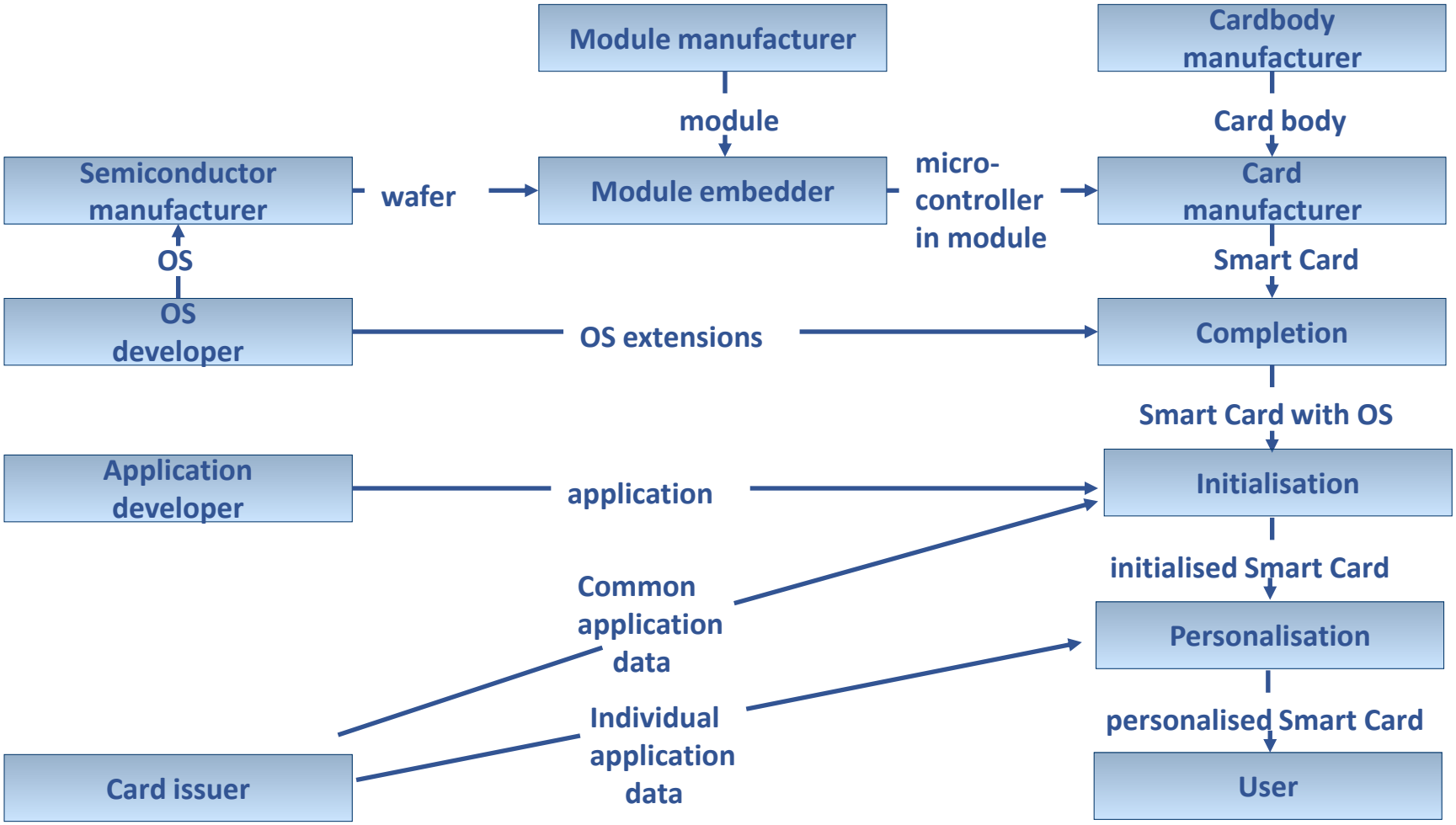
Contact Microcontroller with Flash



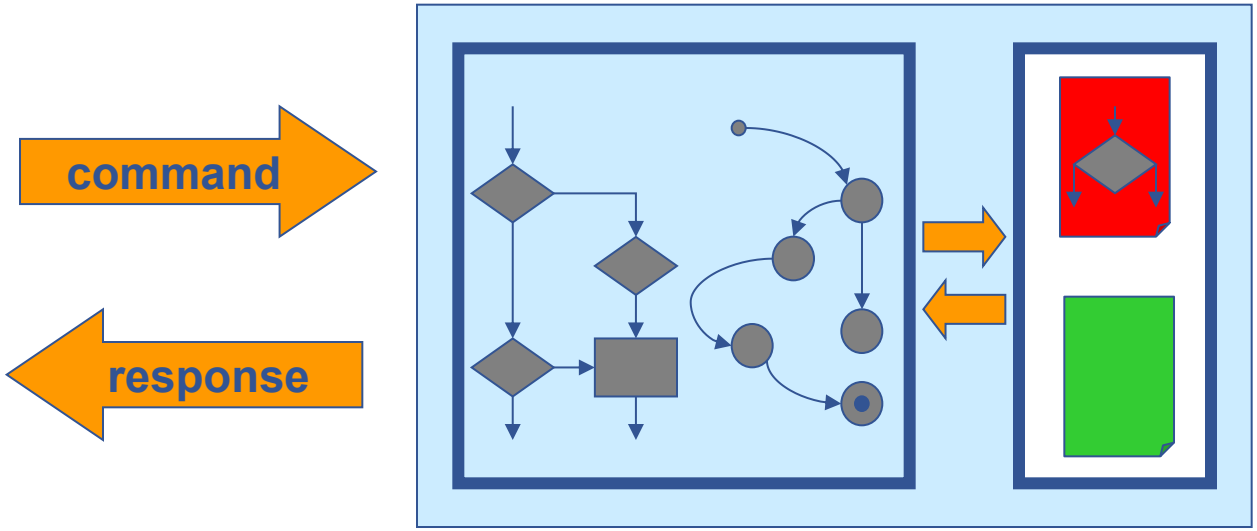
Contactless Microcontroller with ROM



Roles and Interactions

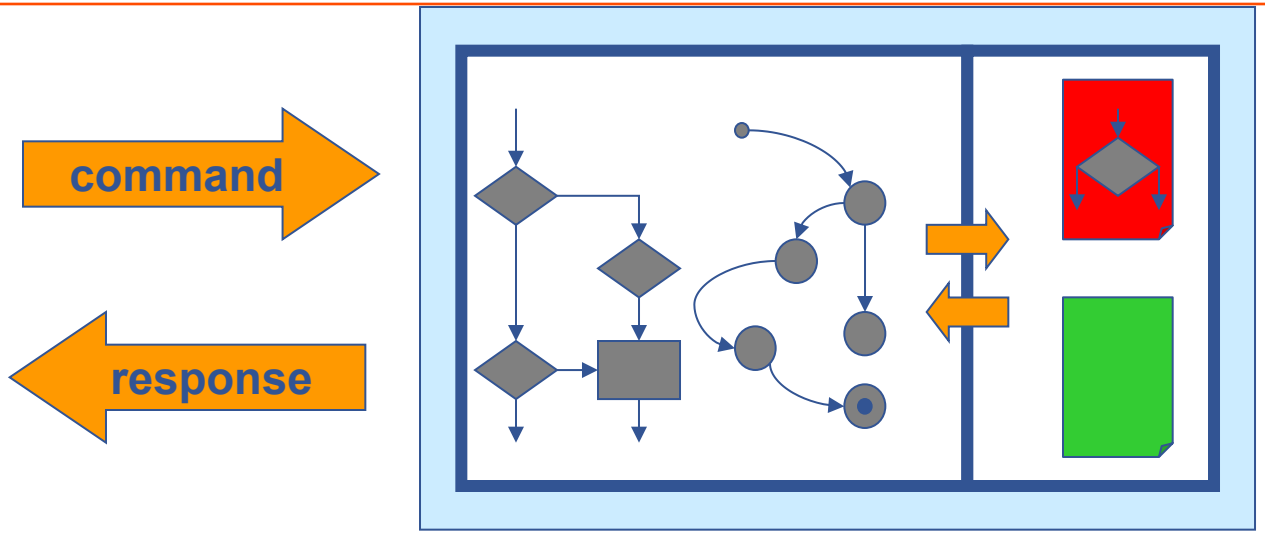


File/Memory Based Applications



- **smart card operation system**
  - File/memory administration with access rights
  - construction kit
  - for applications with middle complexity
- **pro/contra**
  - easy application building
  - no programming
  - robust
  - less error risk

Code Based Applications



- **smart card operating system**
  - Interpreter for program code
  - Java Card, Basic Card
  - for applications with high complexity
- **pro/contra**
  - flexible, optimised for specific applications
  - complex application building
  - know-how is necessary

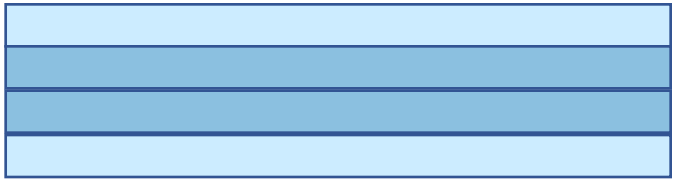
International Standards

ISO/IEC 7810	identification cards	physical characteristics
ISO/IEC 7811	identification cards	part 1: embossing part 2: magnetic stripe part 3: location of embossed characters on ID-1 cards part 4: location of read-only magnetic tracks track 1 + 2 part 5: location of read-write magnetic track 3
ISO/IEC 7812	identification cards	numbering system and registration procedure for issuer identifiers
ISO/IEC 7813	identification cards	financial transaction cards

ISO/IEC 7816	integrated circuit(s) cards with contacts	part 1: physical characteristics
		part 2: dimensions and location of the contacts
		part 3: electronic signals and transmission protocols
		part 4: inter-industry commands for interchange
ISO/IEC 10373	identification cards	test methods
ISO/IEC 2894	embossing credit cards	specifications, numbering systems and registration procedure
ISO/IEC 14443	Contactless integrated circuit(s)	Part 1: Physical Part 2: RF/Signal Interface Part 3: Initialisation/Anti-collision Part 4: Transmission Protocol

Card Body Types

laminated multi-layer card



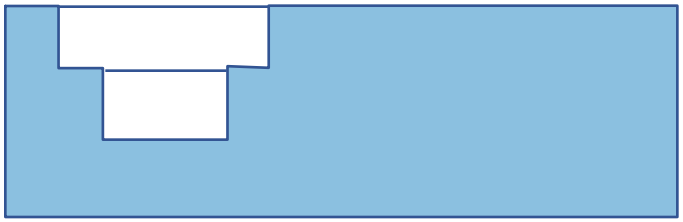
front overlay

core films

reverse overlay

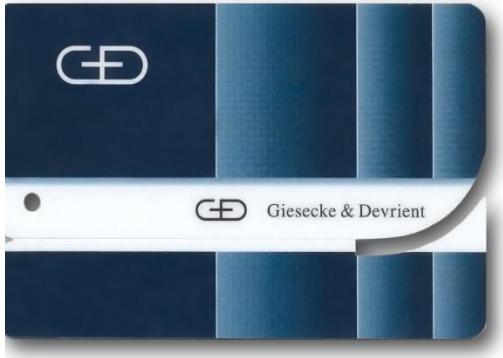
mono-layer card

injection molded card



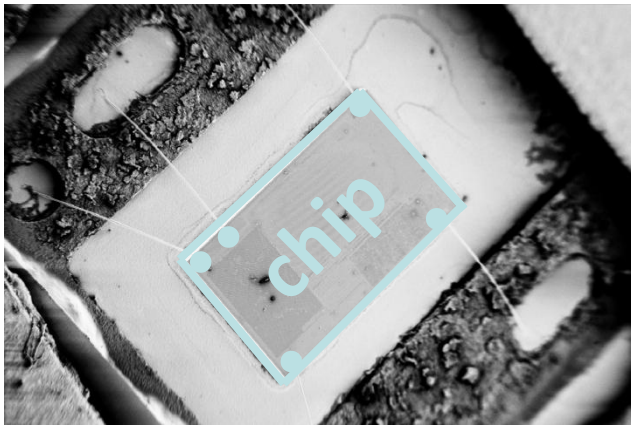
Main Form Factors

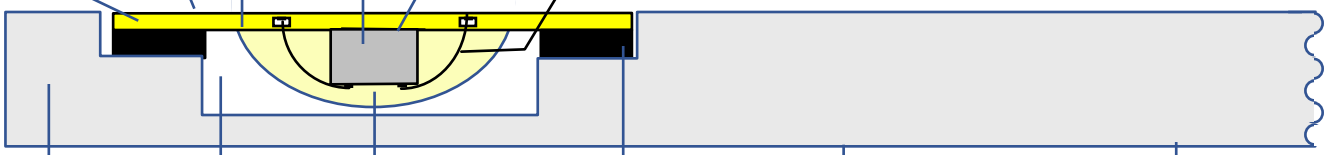
Card Type	Size	Usage
ID-1	54,0 x 85,6 mm	usual smart card
Plug-In Telecommunication	15,0 x 25,0 mm	for
Micro-SIM, Mini-UICC, 3FF Telecommunication	12,0 x 15,0 mm	for
Visa Mini	40,0 x 65,6 mm	for Payment



Visa Mini Source: http://discovered.com.ua/glossary/visa-mini/

Material Components of Modules





contact carrier: **copper**
nickel

chip adhesive joint: **epoxy resin**

wire connection:
gold

contact surface: **gold**

chip: **doped**
silicon

module carrier tape:
glass fibre-epoxy-tape

card body:
ABS
PVC
PC
PETG

module cavity

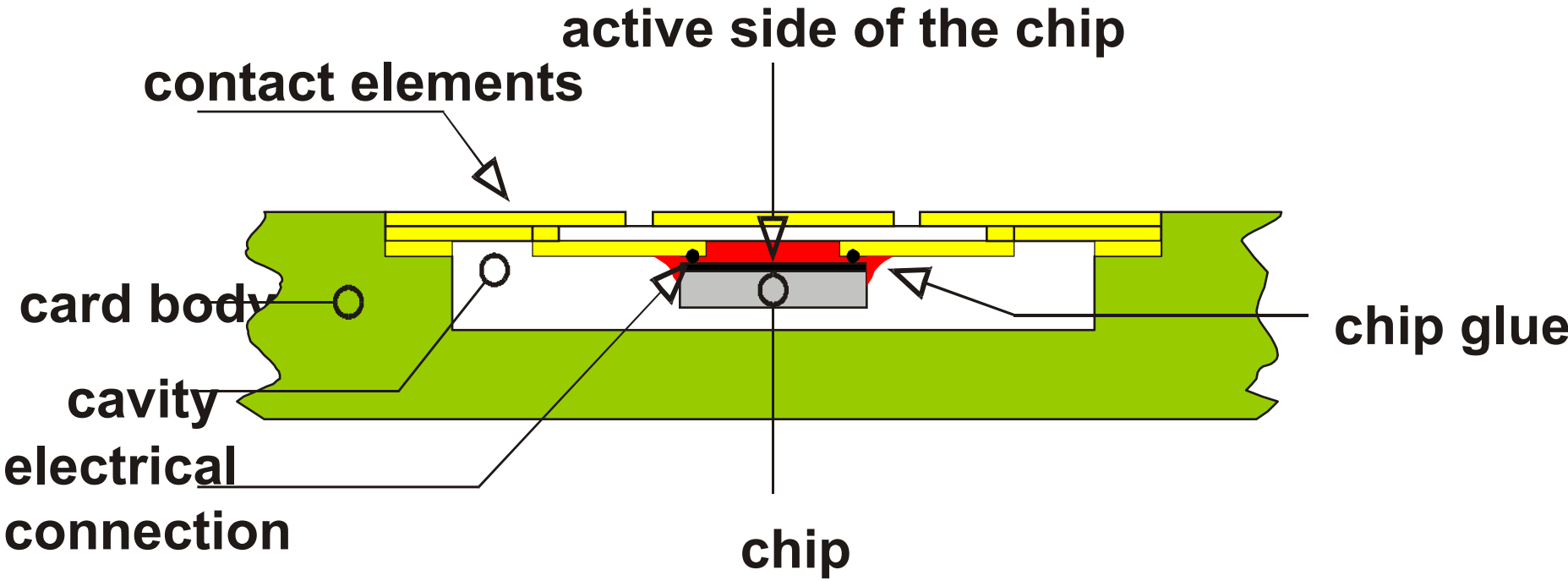
module protection cover:
epoxy resin

module adhesive joint:
hot-melt

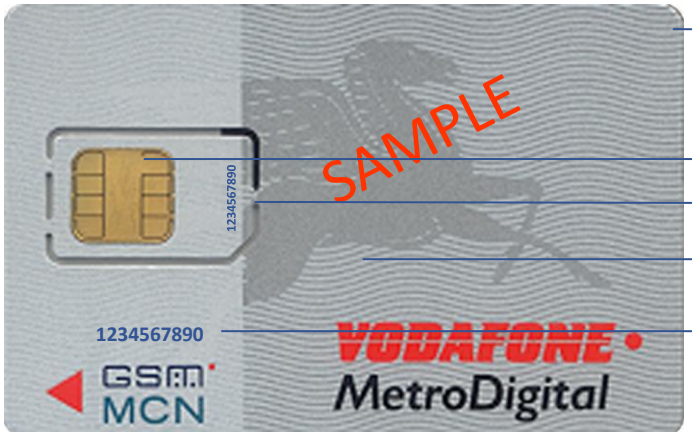
printing inks:
offset inks
screen printing inks
varnish
(**resins, pigments**)

additional card elements:
magnetic stripe: **magnet-oxide**
hologram: **aluminium**
signature panel: **paper**

FCOS - Flip Chip on Substrate



Telecommunication Chip Card



HIGH TEMPERATURE PLASTIC
(multi-layer, mono-layer, injection moulded)

MICROPROCESSOR CHIP

PLUG-IN

MULTI-COLOR PRINT (company logo, advertisment,...)

LASER ENGRAVED or THERMOPRINT
NUMBER PERSONALISATION

FRONT

MULTI-COLOR PRINT
(advertisement, text etc.)

PLUG-IN

REVERSE

All dimensions and positions acc. to ISO-standards.
All prints, texts and additional features on request of card issuer.

Credit Card Type

HIGH TEMPERATURE PLASTIC (multi-layer)

SECURITY PRINT (customer logo, institution logo)

MICRO LINE PRINT

HOLOGRAM (abrasion resistance)

BACKGROUND PRINT

Invisible FLUOR-PRINT

RELIEF EMBOSSING (according to ISO)

FRONT

3-track MAGNETIC STRIPE

FLAT EMBOSSING (indent printing)

fraud resistance: SIGNATURE PANEL (paper, screen or hot stamping)

TEXT PRINT

REVERSE

All dimensions and positions acc. to ISO-standards.
Printing and security features acc. to credit card rules.

ID Card Type

Photograph
- Laser-engraved into the card material
- For tamper-proof protection

Integrated Photo Background
- Harmonious phasing out of the image into the background print
- Overlapping portrait edge and security background

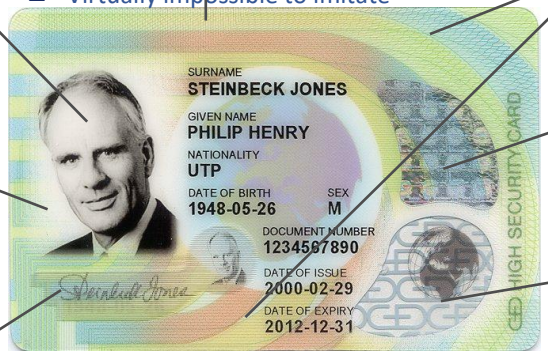
Multiple Laser Image
- Three different card-specific items of information combined in one laser-engraved structure (signature, date of birth, micro photo)

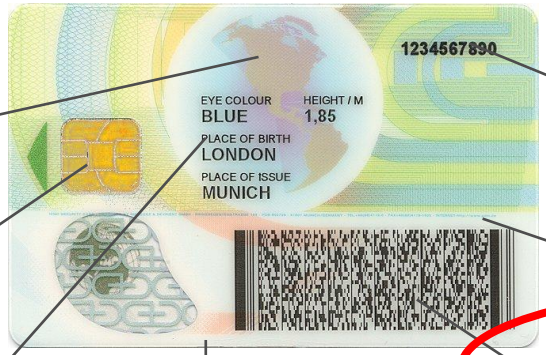
Ultraviolet Fluorescent Inks
- Only visible under ultraviolet light
- Genuineness verification feature

Memory or Microprocessor Chip
- Longlife embedding
- Extended temperature range

Bearer Related Information
- Laser-engraved, i.e. burnt into the card material
- Unequalled protection against manipulation / deterioration

Security Background
- Fine guilloche patterns incorporating the logo
- Rainbow printing
- Virtually impossible to imitate





Material
- Long-life, high-endurance card material (polycarbonate)
- Specifically matched to the laser-engraving process

Surface Structure
- Guilloches and microletters
- Easy visual and tactile verification

Kinegram™ / Hologram
- Artistically designed holographic structure
- Protected by 100 µm overlay foil

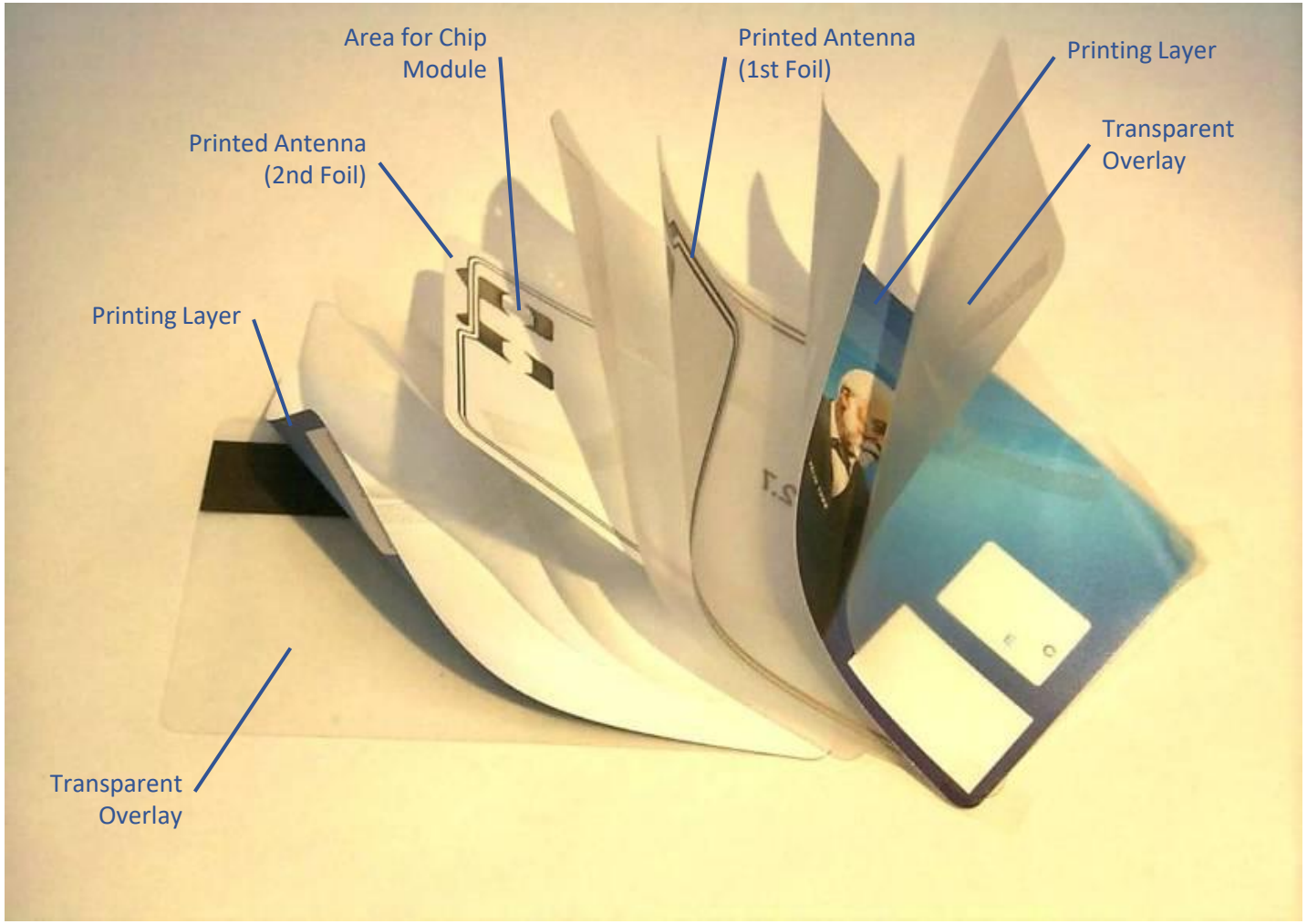
See Through
- Real see through
- Laser engravable
- Front and rearside printing from both sides visible

Tactile Lettering
- Easy tactile and visual verification

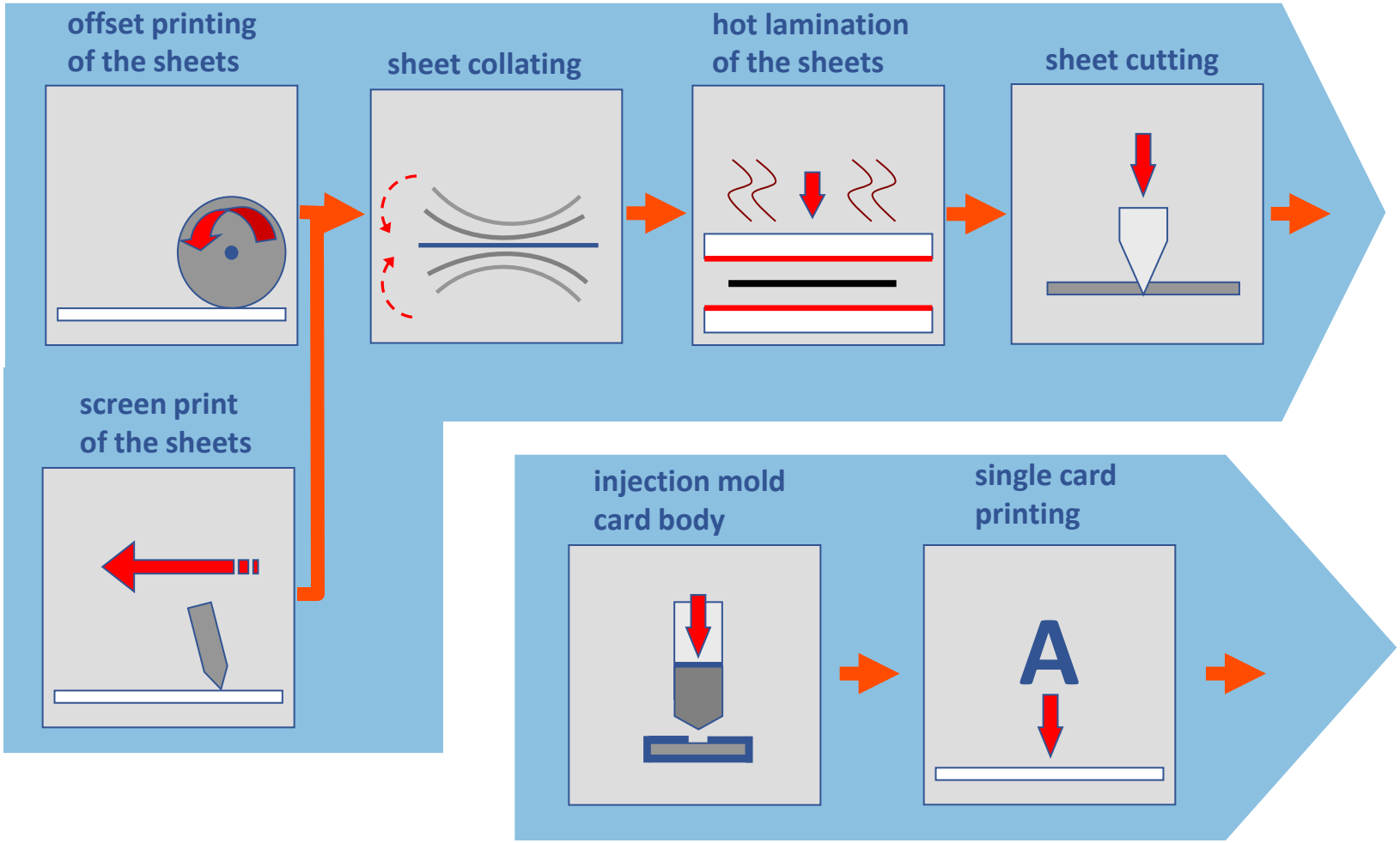
Microprinted Line
- Detectable only with magnifiying glass
- Reproduction not possible with techniques available to counterfeiters

Two-Dimensional Barcode
- Encryption of large amount of data
- Machine-readability

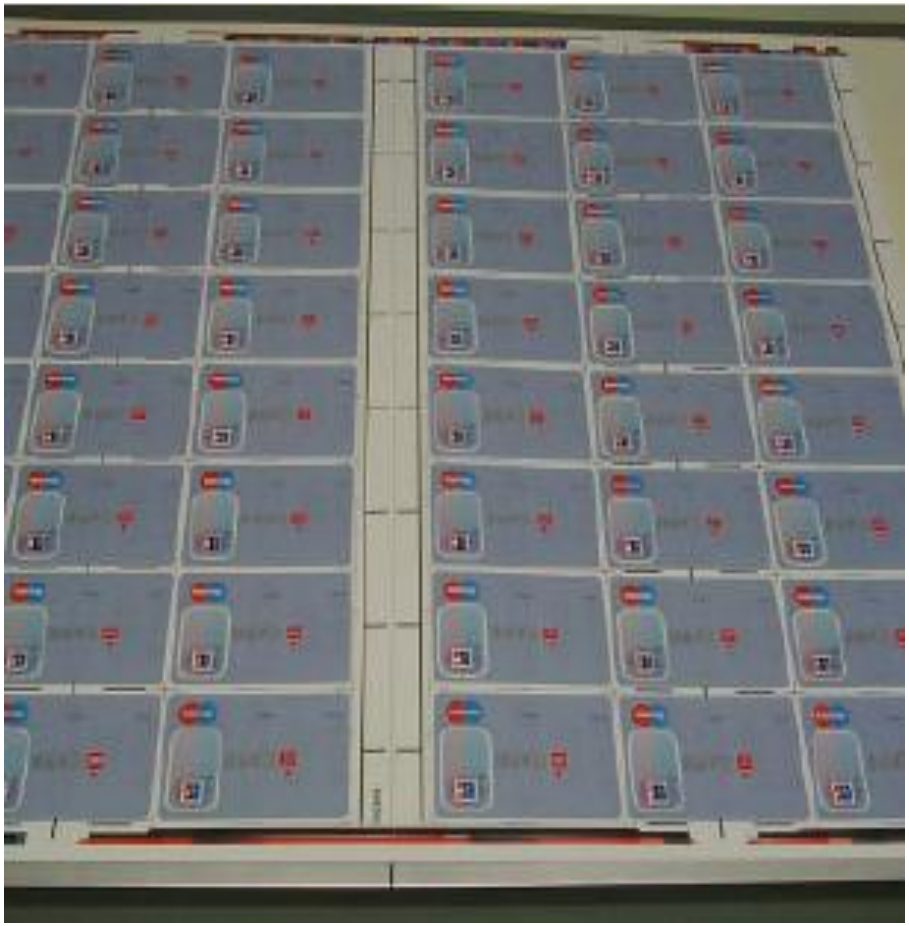
Layers of a Contactless Card



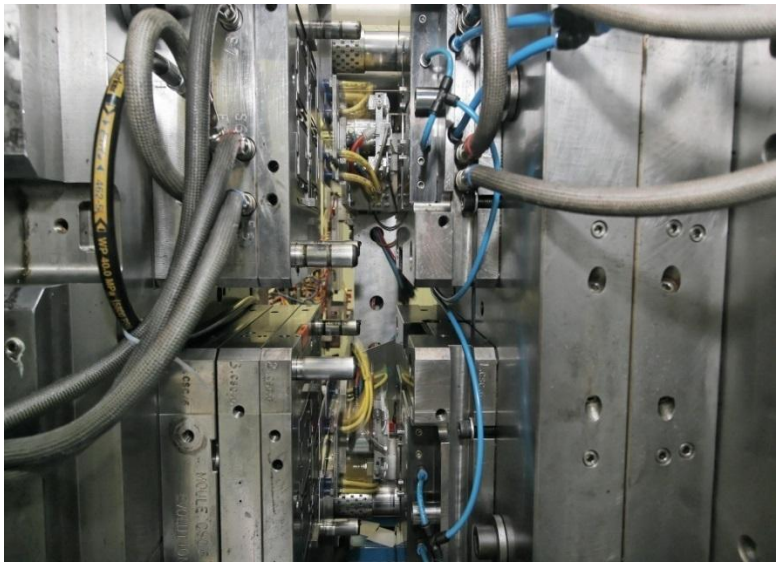
Manufacturing: Plastic to Card Body



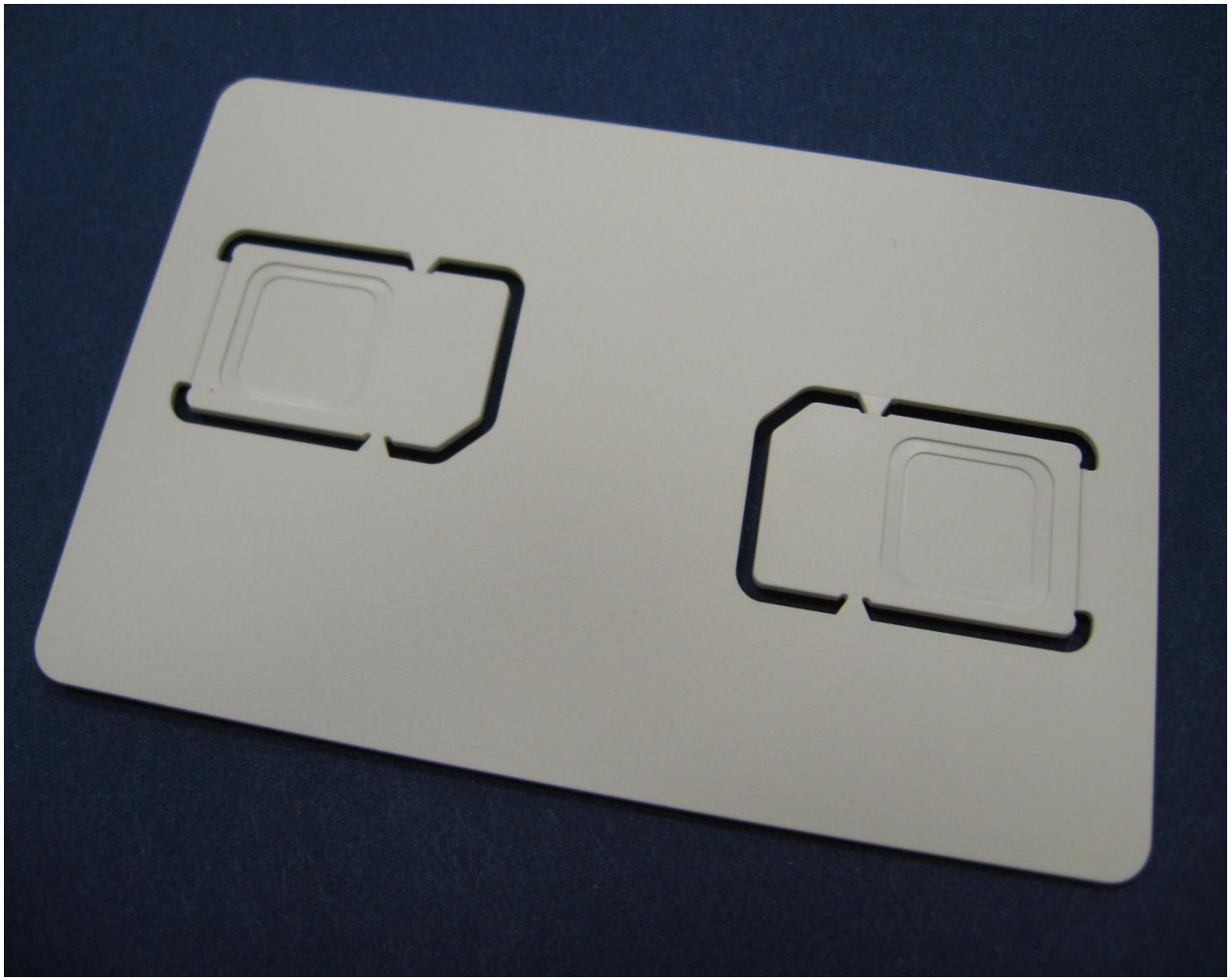
Offset Sheet Printing



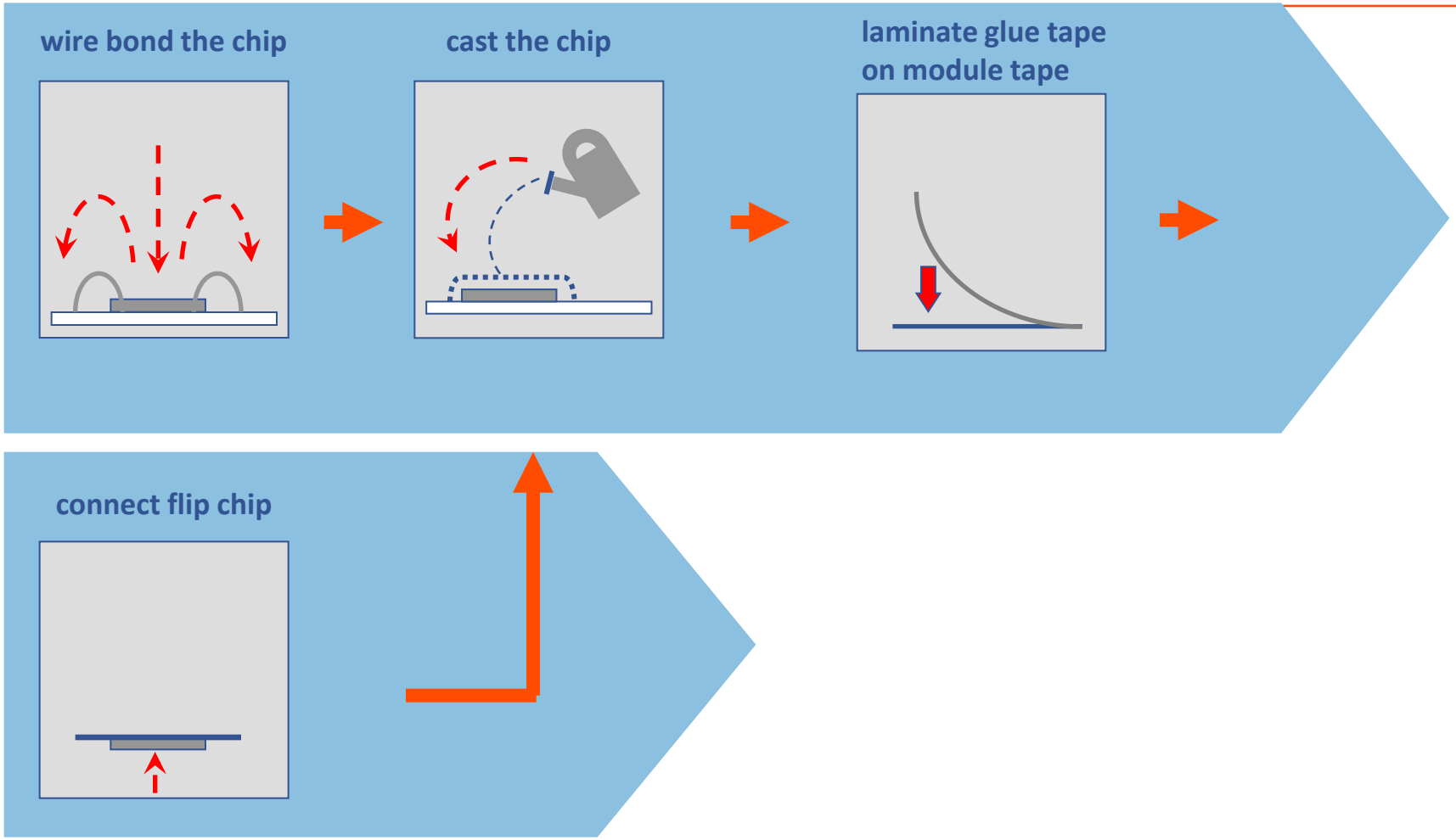
Injection Moulding Machine



Injection Moulded Card

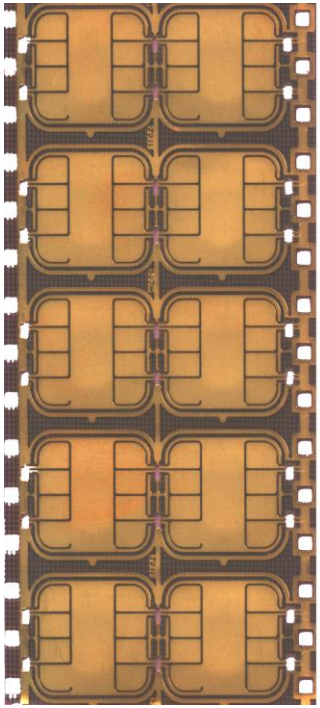


Manufacturing: Chip to Module

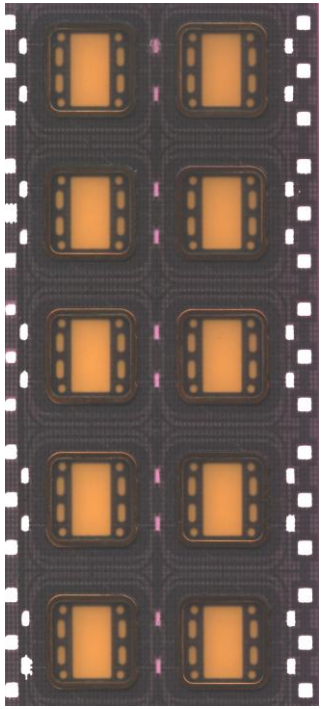


Examples for Module Tapes

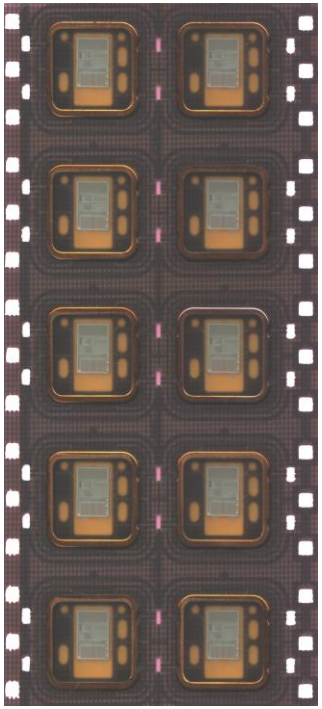
Module tape
(front side)



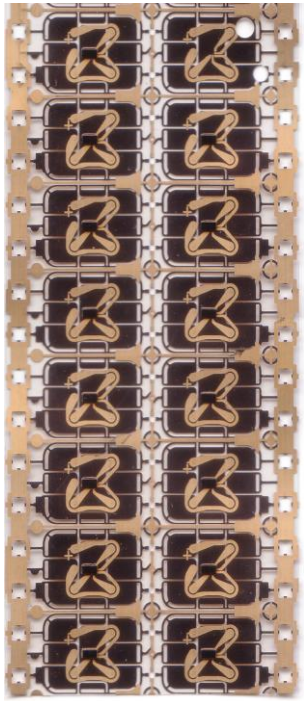
Module tape
without chip
(back side)



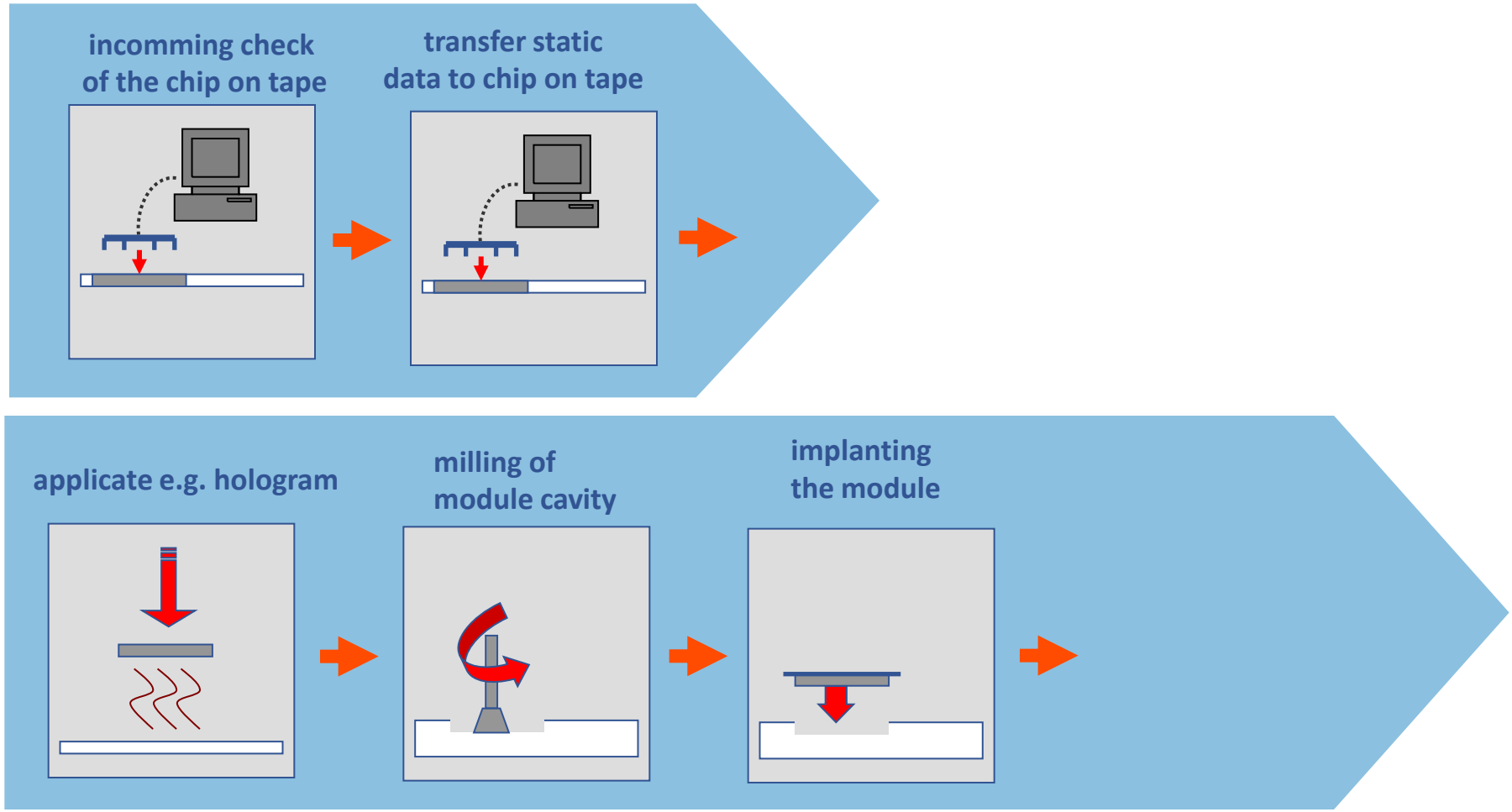
Module tape with
wire bond chip
(back side)



Module tape
with flip chip
(back side)

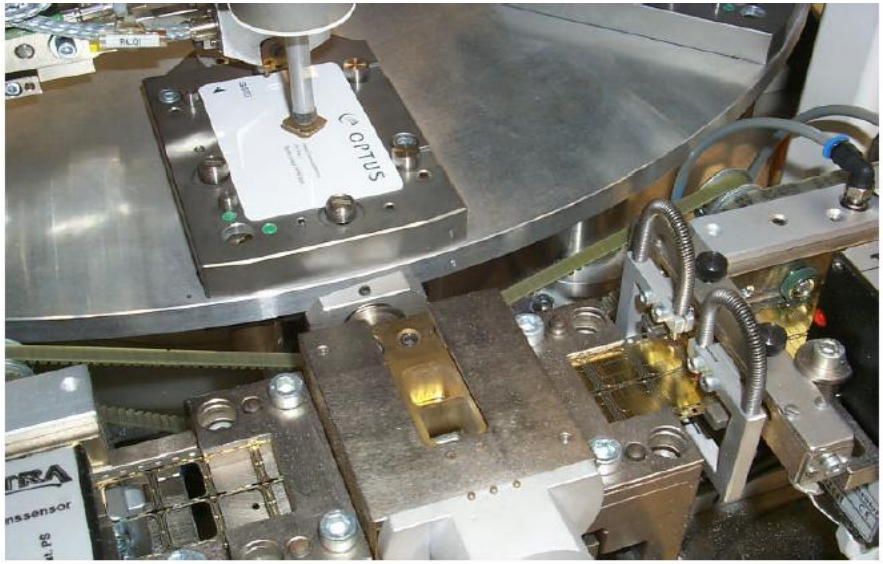


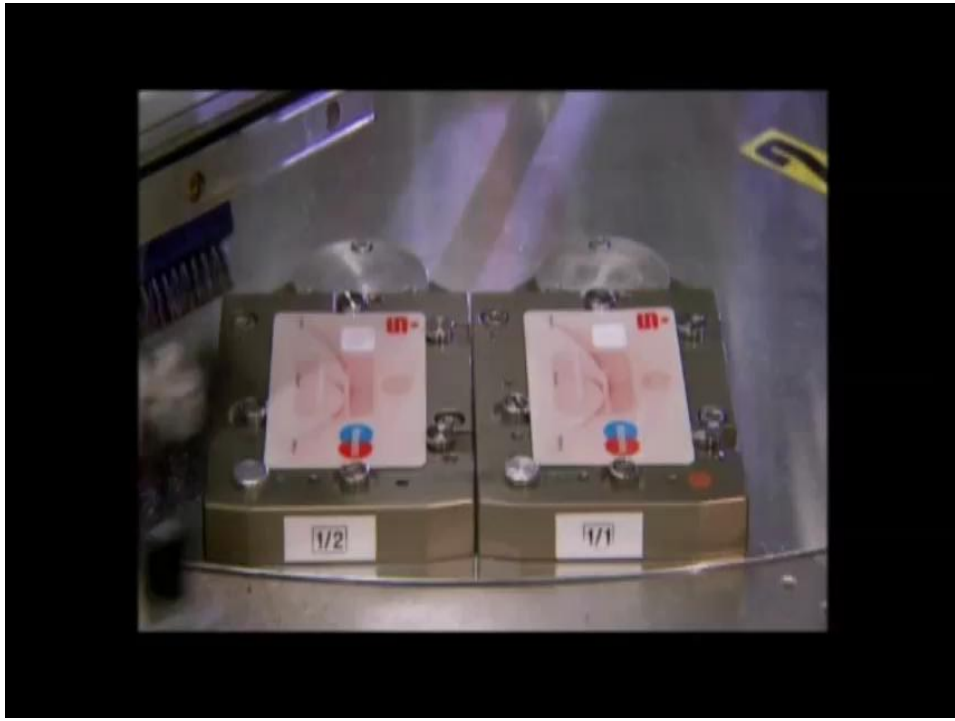
Manufacturing: Module to Chip Card



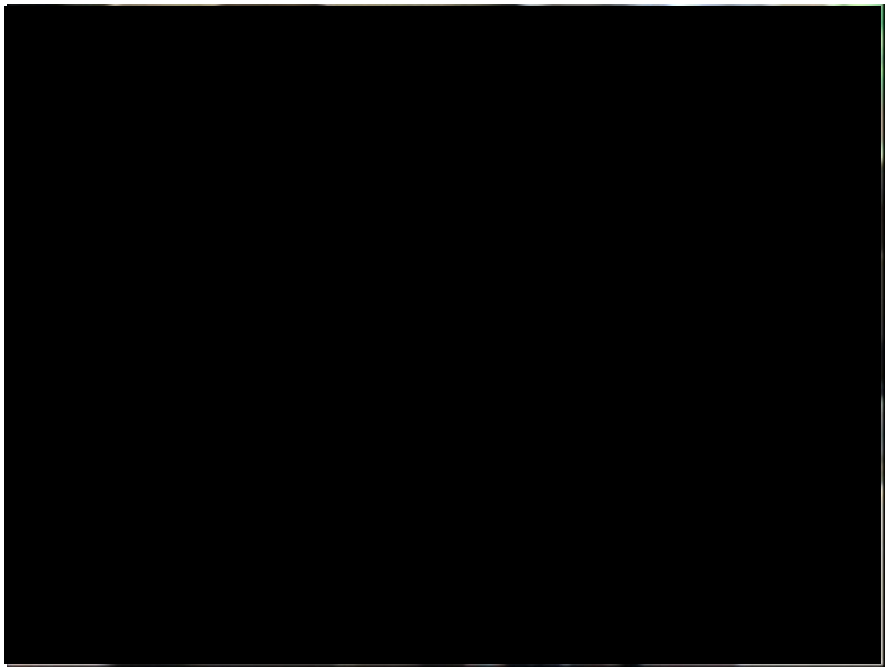
Cavity Milling

Punching and Implantation



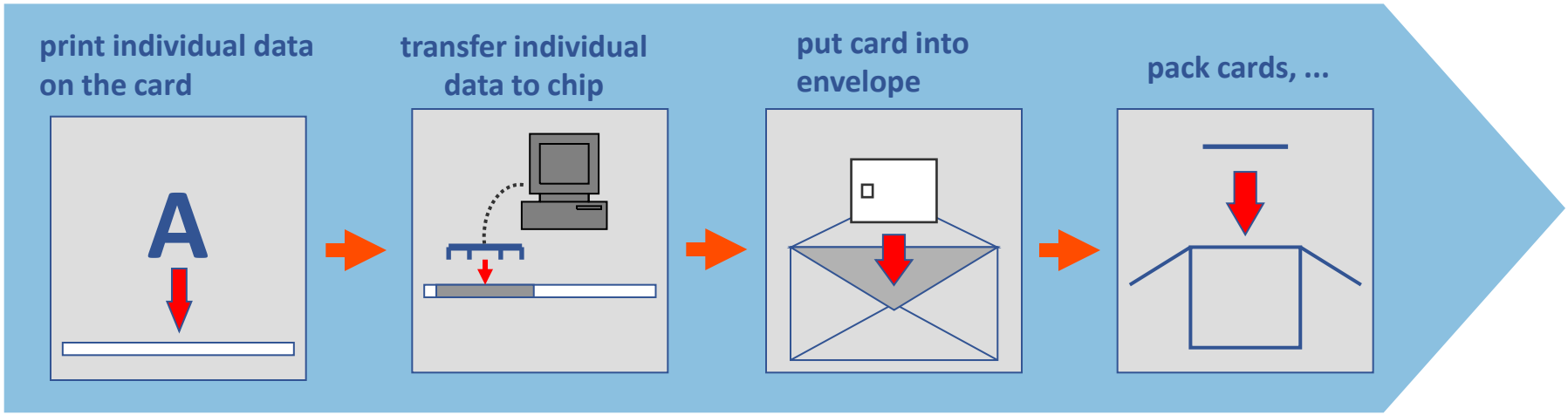


Personalisation Machine



Dynamic Bending Test

Manufacturing: Chip Card to Letter



Packaging and Fulfilment

Bulk Delivery to the Customer

+

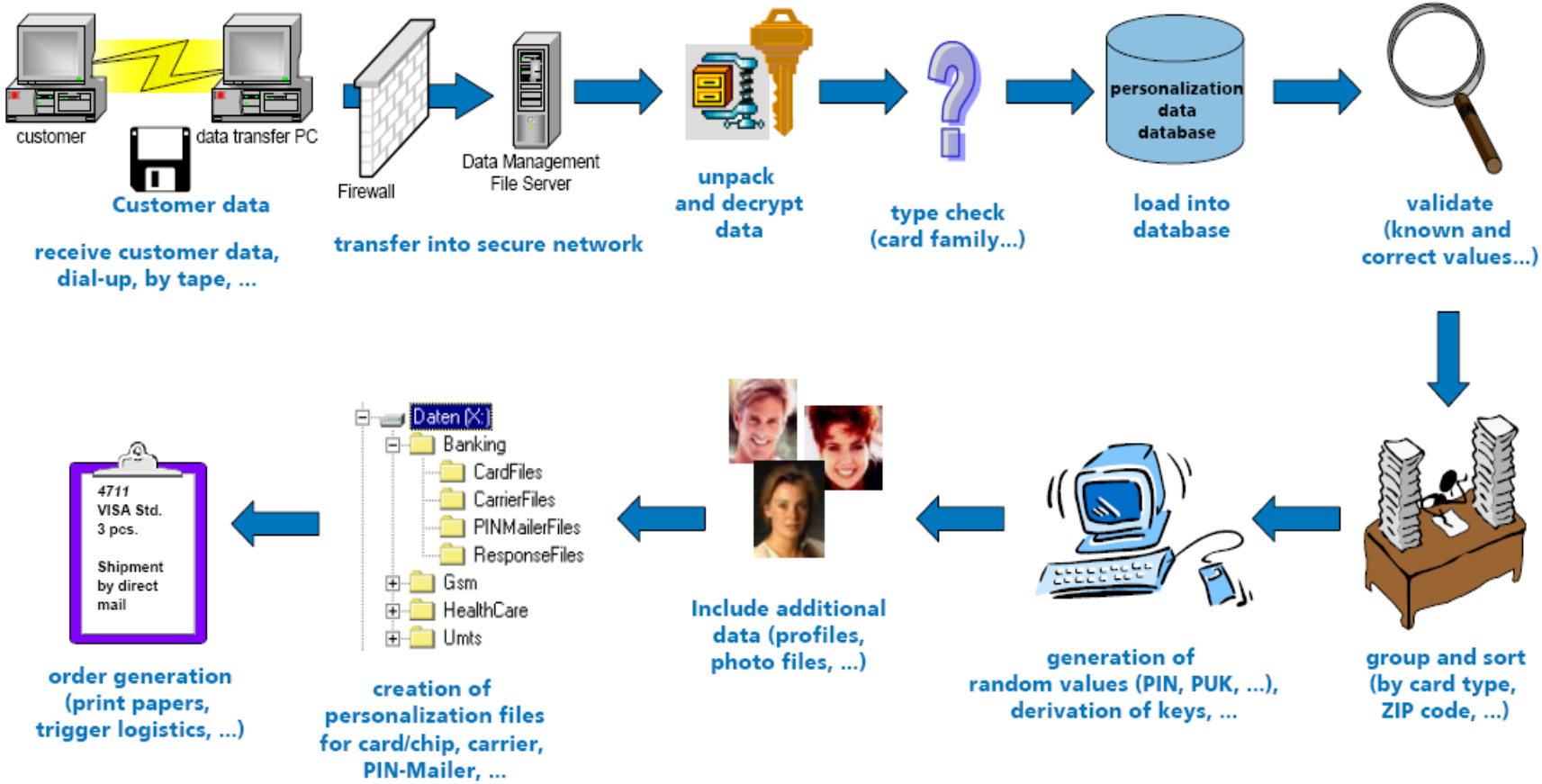
Response Data!

IDs
Keys
PINs
.....

Agenda

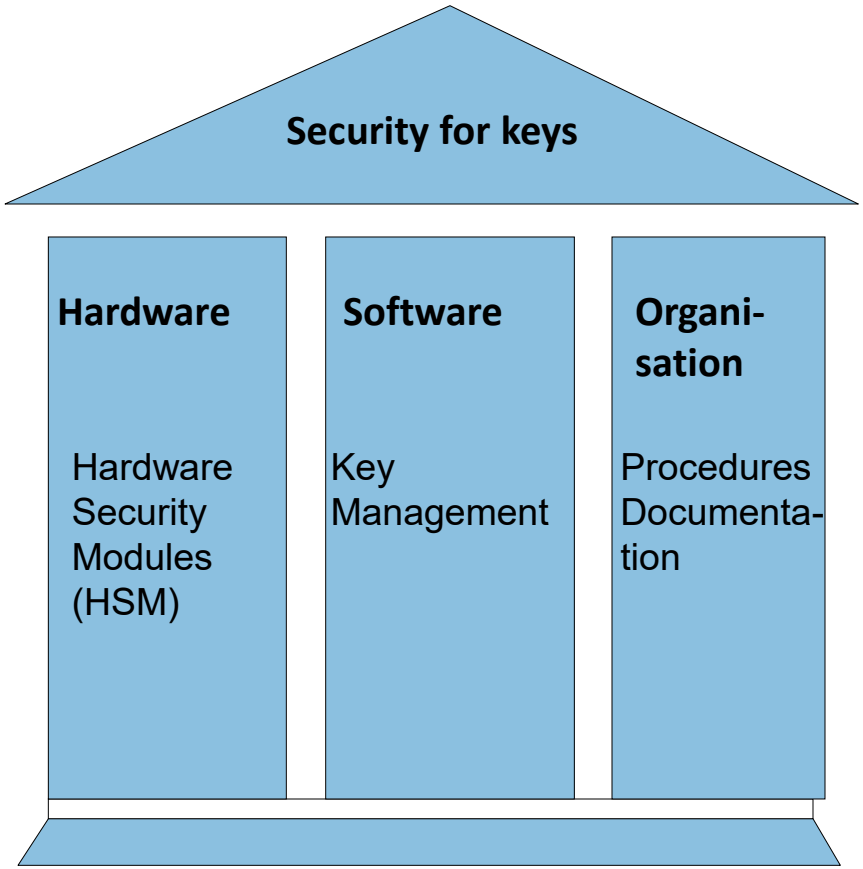
- Some Basics
- Card Manufacturing
- **Key and Data Management**
- **Smart Card Lifecycle – IT Perspective**
- Typical Example

Scope of Key/Data Management



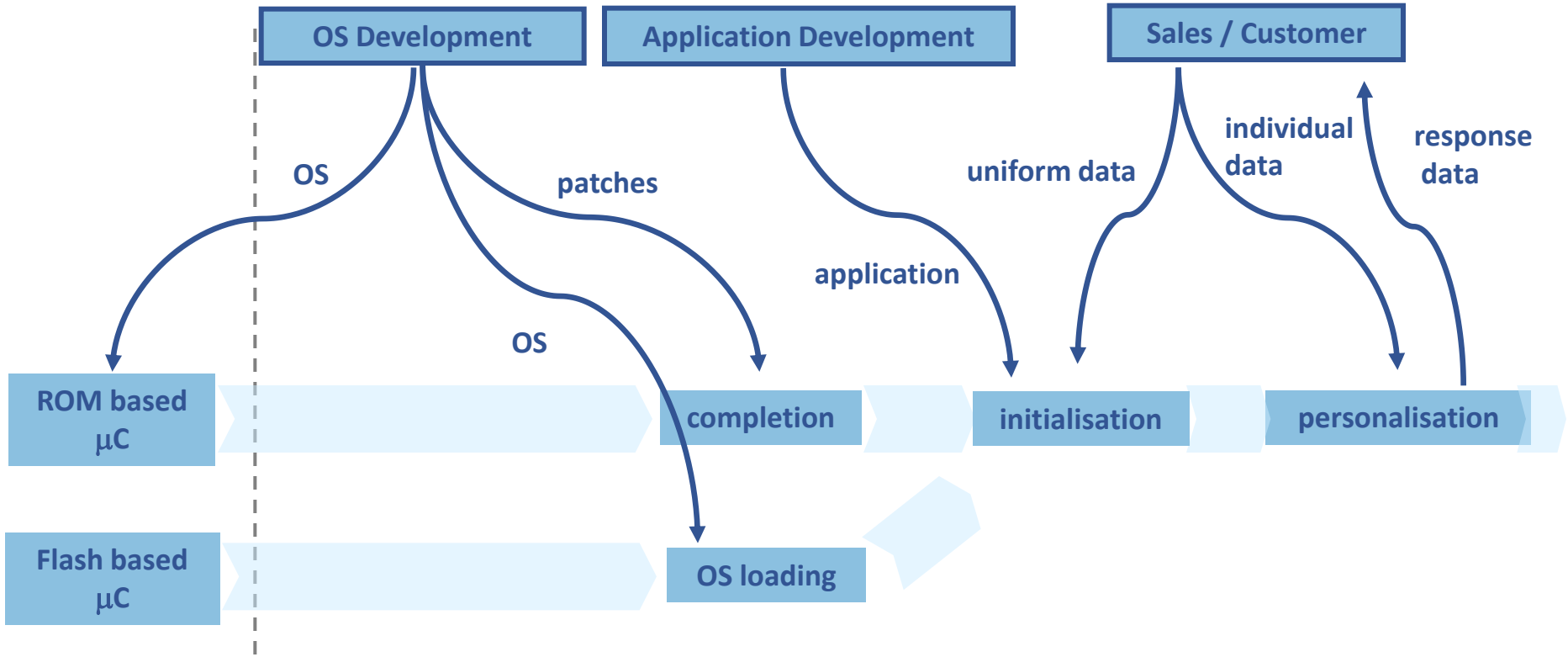
This assumes a physically secure environment!!

Security - Key Management



- There is a range of keys in use e.g.
  - For the system sites
  - For communication between sites
  - For card loading/administration
  - For card transactions
- They require support functionality e.g.
  - Import keys
  - Generate keys
  - Export keys
  - Transport keys
  - Administration of keys

Production Flow of a Smart Card



µC Manufacturer

Card Supplier

Initialisation

Testing

- ROM
- RAM
- EEPROM/Flash

Initialisation

- completion (EEPROM-chip) or loading (Flash-chip) of the operating system
- creating the file structure (MF, EF)
- loading all uniform data
- generating/loading common RSA keys

Process Time

20 sec < t < 150 sec

Personalisation

The personalisation process times have a direct influence on the cost of smart cards as they affect the throughput of expensive production machines.

Physical Writing Processes

- ❑ Laser engraving
- ❑ Embossing
- ❑ Thermo-Transfer printing
- ❑ Thermo-Sublimation printing

Encoding

- ❑ Magnetic stripe and chip

Examples for Process Times

❑ Alphanumeric personalisation	**t < 2 sec**
❑ Thermal personalisation (e.g. photo, barcode)	**t ~ 8 sec**
❑ Laser engraving of a barcode	**t ~ 3 sec**
❑ Laser engraving of a photo	**t ~ 40 sec**
❑ MagStripe-encoding	**t < 2 sec**
❑ Personalisation of memory chip	**t < 1 sec**
❑ Personalisation of microprocessor chip	**10 sec < t < 60 sec**

Important note:

❑ It is faster (hence cheaper) to generate an individual RSA key in a HSM and then load into the card during chip personalisation than to generate the key in the smart card.

❑ However, the private key is then known to the card vendor.

Production Attack Surface

Stage	Threat	Control
Wafer / Chip Fabrication	Substitution, overproduction	Secure sourcing, audits
OS & Application Loading	Malicious code insertion	Code signing, HSM control
Module Embedding	Physical tampering	Secure facilities
Initialisation	Key disclosure	Dual control, key ceremonies
Personalisation	Data or PIN leakage	HSM, access control
Packaging / Fulfilment	Response data exfiltration	Encrypted transfer, logging

State Machine Control of Actions

- Introduce administrative commands
- Realise state machine for correct sequence, done by Smart Card OS
  - for loading the Smart Card OS
  - for loading applications code
  - for loading application data
- Allowable actions are limited by the lifecycle state, for example….
  - Memory test modes are disabled after completion
  - File creation may be disabled after initialisation

Basic Commands for Initialisation, Personalisation

- SELECT
- CREATE FILE
- UPDATE BINARY
- UPDATE RECORD
- EXTERNAL AUTHENTICATE

Commands for Applet Loading (Global Platform)

- LOAD
- INSTALL
- PUT KEY
- STORE DATA
- SET STATUS
- DELETE

Technical Aspects (1)

Field of Usage → Technical Aspects → Governm. & Commercial Aspects → Order → Sample Card Production → Release Card Production → Volume Production

Card Body

- ☑ Body Size (ID1, **Plug-In,** Mini-UICC, Visa-Mini, Special format)
- ☑ Card body type (mono layer, laminated multi layer, **injection molded**)
- ☑ Interface Technology (**contact**, contactless)
- ☑ Standard Conformance (ISO, **ETSI**, ...)
- ☑ **Specification Conformance**

Microcontroller

- ☑ ROM or **Flash** based microcontroller
- ☑ Interface Technology (**contact**, contactless, dual interface)
- ☑ **Operating System** (ISO, **ETSI**, ...)
- ☑ **Java** / native
- ☐ Asymmetric Cryptography (RSA, ECC)
- ☑ **NVM size** (**Flash**, EEPROM)

Technical Aspects (2)

Field of Usage → Technical Aspects → Governm. & Commercial Aspects → Order → Sample Card Production → Release Card Production → Volume Production

Common Card Elements

- ☑ Printing Technology (**offset print**, screen print)
- ☐ Hologram
- ☐ Security Features
- ☐ Signature Panel
- ☑ **Artwork** (who provides, special style, special colors)

Card individual Elements (delivery of card individual data necessary)

- ☐ Magnetic Stripe (incl. Data)
- ☐ Embossing
- ☐ Photo (incl. format, delivery)
- ☐ Laser Engraving
- ☑ **Thermo Transfer Print**
- ☐ Barcode
- ☐ Hologram

Governmental/Commercial Aspects

Field of Usage → Technical Aspects → Governm. & Commercial Aspects → Order → Sample Card Production → Release Card Production → Volume Production

Commercial Aspects

- ☑ **Price**
- ☑ **Liability**
- ☑ **Confidentiality**
- ☑ **Order Process**
- ☐ Forecast procedure
- ☐ Production on Demand

Governmental Aspects

- ☑ **Environment protection**
- ☐ Export regulation
- ☑ **Tax**
- ☐ Key escrow

Ordering Aspects

Card Data

- ❑ Delivered by purchaser (in which way and format)
- ☑ **Generated by card manufacturer**
- ☑ **Response data (delivery way and format)**

Note: Response data is very critical/important!!

- ❑ It contains all the IDs/Keys/PINs for all cards in the order
- ❑ Usually loaded into customers secure database (AuC in mobile networks)
- ❑ If attackers get access to the response files or database they may be able to create many clones!

Scope of Key/Data Management

- This assumes a physically secure environment!
  - Production keys underpin authentication, encryption, and device trust
  - Keys must be generated in certified Hardware Security Modules (HSMs)
  - Key handling requires dual-person control and secure ceremonies
  - Keys must be protected during storage and transfer
  - Compromise enables large-scale device cloning and loss of integrity

Copyrighted Images belong to their original designers owners
Original slides from Keith Mayes and G&D

Thank you for your attention…

Any Questions?

Royal Holloway
University of London